

IT GOVERNANCE FINAL ROUND

LGPD - PARTE 1



7

LISTA DE FIGURAS

Figura 1 – Privacidade on-line.....	4
Figura 2 – Mark Zuckerberg – CEO Facebook.....	6
Figura 3 – Presidência da República – Casa Civil.....	7
Figura 4 – Alusão a dado anônimo.....	9
Figura 5 – Consentimento e proteção de dados.....	10
Figura 6 – DPO	12
Figura 7 – Data from Gartner’s 2017 LGPD webinar among clients in Brazil	15
Figura 8 – Top Secret.....	16
Figura 9 – SIEM	19

SUMÁRIO

LGPD	4
1 LGPD: ESTÁ PREPARADO?	4
1.1 Introdução	4
1.2 A privacidade e a lei	5
2 ESTRUTURA DA LEI 13.709/2018	6
2.1 Principais Pontos da Lei	8
3 A LGPD E SEU IMPACTO NAS EMPRESAS BRASILEIRAS.....	13
4 O PAPEL DA TI NA LGPD	16
REFERÊNCIAS.....	21
GLOSSÁRIO	23

LGPD

1 LGPD: ESTÁ PREPARADO?

Vamos falar aqui da LEI GERAL DE PROTEÇÃO DE DADOS – LGPD (13.709/2018), de 14 de agosto de 2018, que dispõe sobre a proteção de dados pessoais e altera a Lei nº 12.965, de 23 de abril de 2014 (Marco Civil da Internet).

Em síntese, a legislação brasileira, que passou a vigorar em setembro de 2020, regulamenta como os dados de pessoas físicas podem ser coletados e tratados por qualquer tipo de organização, pública ou privada.



Figura 1 – Privacidade on-line
Fonte: Google Imagens (2018)

1.1 Introdução

Na compra de medicamentos em uma farmácia, muitos fornecem seu CPF para, por exemplo, obter descontos. Todas essas informações ficam registradas e vinculadas a seu nome. O que é possível fazer com essas informações?

Talvez, abastecer, com dados, os laboratórios quanto aos seus hábitos de consumo e ou comercializá-los com planos de saúde e seguradoras para análise de risco, dentre outros. Independentemente do destino de suas informações, a principal questão é: esse uso tinha a ciência do proprietário ou foi autorizado por ele? Ou o único intuito era a obtenção do desconto?

1.2 A privacidade e a lei

Além do cenário hipotético, basta acompanhar a mídia especializada para nos depararmos, quase que diariamente, com notícias relacionadas à exposição não autorizada de dados pessoais, como nomes, endereços físicos e/ou eletrônicos, números de documentos, números de cartões de créditos etc., seja por exploração de vulnerabilidades tecnológicas, seja por falta de cuidado e/ou atenção do proprietário destas informações – quando este compartilha informações em ambientes tecnológicos públicos, como redes sociais, como se fossem privados, ou quando aceita termos de uso sem ler as condições. É exatamente isso: **você** liberou seus dados quando clicou em “aceito os termos de uso” do site ou serviço sem a devida atenção às suas cláusulas.

Como mencionado no resumo inicial, diversos serviços utilizados atualmente coletam dados pessoais do usuário e os problemas relacionados ao uso indiscriminado ou sem consentimento destas informações colocam luz ao tema privacidade e fomentam a criação de uma regulamentação específica.

De acordo com Araújo (2017):

O direito à privacidade encontra-se disposto no art. 5º, X, da CRFB /88 e incluem-se nesta nomenclatura os direitos à intimidade, à vida privada, à honra e à imagem, direitos distintos e autonomamente considerados. O direito à privacidade já não é uma questão Estado-Indivíduo. Extrapola para a dimensão Estado-Indivíduo-Sociedade, e mais, trata-se de um arcabouço político-jurídico a ser construído em um novo paradigma.

A mesma autora enfatiza que:

A crescente exposição que a tecnologia da informação gera na existência de cada indivíduo exige a rediscussão do direito constitucional à privacidade. Compete apenas ao cidadão escolher se vai ou não contar a sua história, desvelando a sua intimidade e vida privada.

Com tudo isso, surgem os questionamentos: “será que estamos vendo só a ponta do iceberg? Será que o problema vai aumentar?”.

As regulamentações que tratam do tema, como a GDPR (Europeia) e a Lei Geral de Proteção de Dados – LGPD, surgem como respostas a estes questionamentos.



Figura 2 – Mark Zuckerberg – CEO Facebook
Fonte: Amy Osborne/Getty Images (2019)

2 ESTRUTURA DA LEI 13.709/2018

Em 10 de julho de 2018, após uma rápida passagem pelo Senado, sem qualquer alteração ao texto original, a Lei Geral de Proteção de Dados foi aprovada e sancionada pelo, até então, Presidente da República em 14 de agosto desse mesmo ano.

Sua estrutura é composta por 65 artigos distribuídos em 10 capítulos:

- Capítulo I - Disposições preliminares.
- Capítulo II - Do tratamento de dados pessoais.
- Capítulo III - Dos direitos do titular.
- Capítulo IV - Do tratamento de dados pessoais pelo poder público.
- Capítulo V - Da transferência internacional de dados.
- Capítulo VI - Dos agentes de tratamento de dados pessoais.
- Capítulo VII - Da segurança e das boas práticas.
- Capítulo VIII - Da fiscalização.
- Capítulo IX - Da autoridade nacional de proteção de dados (ANPD) e do conselho nacional de proteção de dados pessoais e da privacidade.
- Capítulo X - Disposições finais e transitórias.

Segundo Corrêa (2018), trata-se de lei revolucionária e tão importante ou mais do que foi a vigência do Código de Defesa do Consumidor.

Apesar de grande relevância no contexto de garantias à privacidade do indivíduo, destacam-se as cifras envolvidas em eventuais sanções em razão de infrações cometidas por organizações.

- **Art. 52.** Os agentes de tratamento de dados, em razão das infrações cometidas às normas previstas nesta Lei, ficam sujeitos às seguintes sanções administrativas aplicáveis pela autoridade nacional:
 - II - multa simples, de até 2% (dois por cento) do faturamento da pessoa jurídica de direito privado, grupo ou conglomerado no Brasil no seu último exercício, excluídos os tributos, limitada, no total, a R\$ 50.000.000,00 (cinquenta milhões de reais) por infração.

Em 07/05/2019, a comissão mista do Congresso que analisa a Medida Provisória 869/18 aprovou o relatório que cria a Autoridade Nacional de Proteção de Dados – ANPD e, entre outras mudanças, propõe a negociação e o eventual pagamento de indenização nos casos em que o usuário seja prejudicado por falhas no uso de dados. O texto foi enviado à Câmara dos Deputados, aprovado em 28/05/2019 e seguiu para o Senado, que também aprovou a MP na mesma data.



Presidência da República
Casa Civil
Subchefia para Assuntos Jurídicos

Figura 3 – Presidência da República – Casa Civil
Fonte: Google Imagens (2019)

A Autoridade Nacional de Proteção de Dados – ANPD é composta por 21 representantes, sendo 5 indicados pelo Poder Executivo, 3 pela sociedade civil, 3 por instituições científicas, 3 pelo setor produtivo, 1 pelo Senado, 1 pela Câmara dos Deputados, 1 pelo Conselho Nacional de Justiça, 1 pelo Conselho Nacional do Ministério Público, 1 pelo Comitê Gestor da Internet, 1 por empresários e 1 por trabalhadores e tem como atribuições zelar pela observância de segredos comerciais

e industriais e realizar auditorias sobre o tratamento de dados pessoais, além de requisitar informações e comunicar às autoridades sobre infrações penais ou descumprimento da Lei Geral de Proteção de Dados Pessoais (LGPD).

Medida Provisória nº 869, de 2018: Altera a Lei nº 13.709, de 2018, para criar, como órgão da administração pública federal, a Autoridade Nacional de Proteção de Dados - ANPD, estabelecendo sua composição e suas competências e garantindo sua autonomia técnica. Altera a Lei nº 13.502, de 2017, de forma a incluir a ANPD na estrutura da Presidência da República. Promove outras alterações na Lei nº 13.709, de 2018, para dispor sobre a proteção de dados pessoais.

A íntegra da Lei pode ser lida neste endereço eletrônico:
<http://www.planalto.gov.br/ccivil_03/ato2015-2018/2018/lei/L13709.htm>.

2.1 Principais Pontos da Lei

Como já mencionado, trata-se de uma lei revolucionária e de grande relevância. Dos 65 artigos distribuídos em 10 capítulos, naturalmente toda a estrutura da Lei é importante, mas alguns tópicos merecem destaque e serão abordados a seguir:

Art. 3º Esta Lei aplica-se a qualquer operação de tratamento realizada por pessoa natural ou por pessoa jurídica de direito público ou privado, independentemente do meio, do país de sua sede ou do país onde estejam localizados os dados [...] (BRASIL, 2018).

O legislador busca, em semelhança ao modelo adotado pela União Europeia, proteger os dados pessoais de brasileiros e/ou os coletados em território nacional. A seguir, no Artigo 4º, a lei estabelece suas exceções.

Art. 4º A Lei não será aplicada quando o tratamento de dados for realizado por pessoa natural, com finalidade particular e sem viés econômico. Houve exceção, também, para as atividades jornalísticas, artísticas e acadêmicas além de informações necessárias à segurança pública (BRASIL, 2018).

Até este ponto, a expressão “dados pessoais” foi citada algumas vezes, mas é importante entender como a Lei define tais termos:

- **Dado pessoal:** Informação relacionada a uma pessoa natural identificada ou identificável.
- **Dado pessoal sensível:** Dado pessoal sobre origem racial ou étnica, convicção religiosa, opinião política, filiação a sindicato ou a organização de

caráter religioso, filosófico ou político, dado referente à saúde ou à vida sexual; dado genético ou biométrico, quando vinculado a uma pessoa natural.

- **Dado anonimizado:** Dado relativo a titular que não possa ser identificado, considerando a utilização de meios técnicos razoáveis e disponíveis na ocasião de seu tratamento.



Figura 4 – Alusão a dado anônimo
Fonte: Smith (2016)

Importante observar a distinção entre **dado pessoal** e **dado pessoal sensível**, já que este último possui características específicas que devem ser observadas no tratamento – **Artigo 7º**.

Independentemente da classificação, a Lei estabelece que o tratamento dos dados pessoais, sensíveis ou não, deve observar diversos princípios, como a finalidade, a adequação e a necessidade entre outros. Um dado pessoal não pode ser coletado simplesmente sob o pretexto de possível utilização futura. Vamos recordar do exemplo do cadastro que fazemos normalmente para acessar prédios comerciais. Imagine que este cadastro contemple, por exemplo, sua foto, nome completo, número de documento, orientação sexual e coleta de biometria.

Em uma análise muito rasa, podemos até encontrar finalidade para estas informações, mas será que todas são adequadas e, principalmente, necessárias?

Todo o contexto será considerado pelo julgador no momento da ocorrência de um incidente envolvendo o uso indevido destas informações.

Ainda que observada a boa-fé e a finalidade da coleta e tratamento destes dados, o **Artigo 7º** estabelece que isso só deve acontecer com algumas exceções legais, mediante o consentimento explícito do titular (dono dos dados).

Vamos voltar ao exemplo do cadastro realizado para acesso ao prédio comercial, neste caso você autorizou expressamente o uso dos seus dados para fins de controle de acesso, porém, como o condomínio em questão já possuía sua autorização, repassou os dados à empresa que disponibiliza conexões Wi-Fi gratuitas aos visitantes (do mesmo condomínio). Mesmo que, aparentemente, exista uma vantagem neste exemplo – poder utilizar a rede Wi-Fi gratuita –, a autorização cobria apenas o controle de acesso e isso configura violação à lei.



Figura 5 – Consentimento e proteção de dados
Fonte: Porto Júnior (2018)

É importante mencionar que o consentimento pode ser revogado a qualquer momento mediante manifestação expressa do titular e isso deve acontecer de forma facilitada e sem grandes burocracias por parte do controlador (a quem competem as decisões referentes ao tratamento de dados pessoais).

Tratamento (Artigo 5º, inciso XII): Toda operação realizada com dados pessoais, como as que se referem a coleta, produção, recepção, classificação, utilização, acesso, reprodução, transmissão, distribuição, processamento, arquivamento, armazenamento, eliminação, avaliação, controle, modificação, comunicação, transferência, difusão ou extração.

Mesmo que com o uso de dados pessoais autorizado expressamente, o controlador está sujeito à ocorrência de incidentes relacionados à segurança. Neste caso (vazamento, cópia indevida, alteração etc.), a instituição é responsável por informar todos os prejudicados pelo incidente, sugerir que troquem as senhas, quando for o caso, e descrever quais procedimentos pretende adotar para que o incidente não se repita, fora as responsabilidades legais.

Agentes de tratamento e controle (Art. 5º):

Controlador: Pessoa natural ou jurídica, de direito público ou privado, a quem competem as decisões referentes ao tratamento de dados pessoais.

Operador: Pessoa natural ou jurídica, de direito público ou privado, que realiza o tratamento de dados pessoais em nome do controlador.

Encarregado: Pessoa indicada pelo controlador para atuar como canal de comunicação entre o controlador, os titulares dos dados e a Autoridade Nacional de Proteção de Dados (Redação dada pela MP nº 869/2018).

Além dos pontos abordados até aqui, é possível observar preocupações do legislador com alguns temas específicos, como o tratamento de dados pessoais de crianças e de adolescentes (**Art. 14**) e todo um capítulo (**IV**) dedicado ao tratamento de dados pessoais pelo poder público.

No caso de crianças e adolescentes, buscou-se garantir que estes tivessem formas de autorizar o uso de seus dados através de consentimento específico dado por pelo menos um dos pais ou pelo responsável legal e o poder público, pois, de modo geral, eles necessitam de dados pessoais como insumos às suas atividades e estas também devem ser reguladas.

Já foram mencionados e definidos, de acordo com a Lei, alguns importantes papéis na busca da conformidade com a LGPD, mas devido à relevância e à criticidade de suas atividades, convém explorar melhor suas responsabilidades, até porque, se você for convidado para assumir um destes papéis (operador/encarregado), comece a analisar a relação custo x benefício.

O controlador ou o operador que, em razão do exercício de atividade de tratamento de dados pessoais, causar a outrem dano patrimonial, moral, individual ou coletivo, em violação à legislação de proteção de dados pessoais, é obrigado a repará-lo. (Lei 13.709, Art. 42).

Isso significa dizer que eventuais incidentes de segurança envolvendo os dados do titular serão objetos de análise jurídica e caso você, na função de operador, não tenha cumprido suas obrigações, poderá responder de forma solidária pelos danos e poderá arcar com pagamento de indenizações ao titular.

E quanto ao encarregado ou, como o mercado está se referindo a esta função em referência à resolução Europeia, o **DPO** – sigla em inglês para *Data Protection Officer*? A função é indicação do controlador e este terá suas informações de contato divulgadas publicamente, de forma clara e objetiva, preferencialmente no sítio eletrônico do controlador (**Art. 41, §1º**) e tem como funções: aceitar reclamações e

comunicações dos titulares, prestar esclarecimentos e adotar providências, receber comunicações da autoridade nacional e adotar providências, além de orientar os funcionários e os contratados da empresa/instituição a respeito das práticas a serem tomadas em relação à proteção de dados pessoais.



Figura 6 – DPO
Fonte: PLANT (2017)

NOTA: As regulamentações de proteção e privacidade de dados, como GDPR e LGPD fizeram crescer a procura por seguros contra riscos cibernéticos. Este tipo de seguro cobre os ativos digitais de uma empresa, seus dados, registros de clientes e funcionários. Entre as coberturas estão a indenização por destruição de dados; o sequestro de dados e pagamento de resgate; o roubo de dados; a paralisação da operação e do negócio; a responsabilidade civil por vazamento de dados, entre outras. Por estas características, o seguro serve de respaldo às funções demandadas pelas regulamentações.

Como já mencionado, toda a estrutura da Lei é importante. Alguns pontos foram explorados até aqui e mais alguns serão tratados adiante, no relacionamento da tecnologia da informação com a LGPD. De forma ampla, temos:

- A primeira e mais importante premissa é a seguinte: alguém só pode coletar ou tratar de qualquer outra forma dados pessoais seus se **você** permitir. O consentimento deve ser manifestação livre, informada e inequívoca pela qual o titular concorda com o tratamento de seus dados pessoais para uma finalidade determinada (Pontes, 2018). O autor exemplifica o desvio de finalidade: o titular autorizou o tratamento de seus dados pessoais para aprimorar um software que ele utiliza; o consentimento foi para isso; no

entanto, agora a empresa do software quer utilizar esses dados para vender anúncios personalizados.

- Em regra, as empresas e as entidades governamentais, precisarão explicar como, quando e por que os dados serão usados.
- Quando for o caso, os usuários poderão pedir aos operadores que forneçam suas informações, podendo promover correções e exclusões.
- Os operadores deverão apagar os dados quando a relação com o cliente terminar.
- A exigência de consentimento é dispensada para dados tornados manifestadamente públicos pelo titular (o que não isenta do cumprimento da Lei).

3 A LGPD E SEU IMPACTO NAS EMPRESAS BRASILEIRAS

Santiago (2018) considera que para a maior parte das empresas e órgãos públicos brasileiros, os dados pessoais são vistos e tratados como um elemento de cunho quase "burocrático", para não dizer banal. As informações sobre os empregados (nome, endereço, férias, salário, auxílios diversos, licenças médicas etc.) são geridas pelo RH com o auxílio de softwares pouco ou nada complexos, segundo o caso. Os contatos dos clientes (ou cidadãos) são tratados artesanalmente, normalmente para fins de envio de faturas, e-mails ou cobranças, e o histórico das compras efetivadas são arquivados para fins de garantia dos produtos adquiridos.

Desde a aprovação da lei de privacidade no Brasil, conhecida como LGPD, esse modelo de gestão tende a desaparecer e as organizações públicas e privadas procuram estabelecer estratégias eficazes na busca da conformidade.

Segundo Neiva e Willemsen (2019), o desafio é equilibrar a conformidade com a proteção da privacidade dos clientes, funcionários, cidadãos, pacientes e consumidores. Além disso, as organizações brasileiras devem buscar esta conformidade como um programa, não um projeto. Ao contrário de um projeto, que tem início, meio e fim, um programa estabelece uma metodologia abrangente que

influenciará permanentemente processos de tomada de decisão e melhorias contínuas de maturidade.

Como exposto, a Lei altera o paradigma de “quanto mais dados, melhor” para a coleta seletiva, ou seja, a captura apenas dos dados que servem a um propósito específico. Essa mudança de paradigma, além de garantir transparência e atender aos princípios da Lei – de finalidade, adequação e necessidade, diminui os riscos relativos a possíveis incidentes de segurança envolvendo estes dados.

Menos dados coletados e armazenados = menos riscos de incidentes.

Neiva e Willemssen (2019) afirmam que as organizações brasileiras precisarão de ajuda de empresas externas que oferecem perspectivas legais, processuais e tecnológicas. O desafio em selecionar o parceiro certo será a falta de referências para confirmar se essas empresas possuem especialização e experiência no assunto ou se estão apenas tentando capitalizar uma nova oportunidade de negócios. Sem uma compreensão clara das etapas mínimas para criar um programa de privacidade, líderes em segurança e gestão de riscos terão dificuldades para priorizar as atividades no curto espaço de tempo.

Segundo a empresa de pesquisa e consultoria Gartner, há muitas mudanças processuais e operacionais necessárias para se preparar um programa para gerenciamento da privacidade. Entre eles, o programa deve incluir implementações tecnológicas, tomada de decisão baseada no risco e clareza sobre papéis e responsabilidades.

Para atender a estes desafios e atuar em conformidade na proteção de dados, Kiyohara (2018) menciona que é recomendável as empresas seguirem quatro etapas fundamentais:

I. Descubra: Identifique e realize o inventário de dados pessoais, incluindo sua classificação, quem controla, quem os processa e como são transferidos.

II. Gerencie: Avalie o nível de proteção de dados em todos os envolvidos, sejam próprios ou terceiros.

III. Proteja: Defina e implante soluções, políticas e governança de dados em toda a organização.

IV. Monitore: Controle e audite continuamente o nível de proteção e avalie constantemente possíveis vazamentos interna e externamente.

Como pode ser observado, toda a organização deve contribuir para o objetivo da conformidade com a Lei, mas um dos atores deste processo ganha destaque especial, o encarregado ou DPO – *Data Protection Officer*.

Engana-se quem pensa que todo advogado está por dentro dessas mudanças e que qualquer pessoa pode resolver os problemas ligados à proteção e privacidade de dados. Existem poucos profissionais que estão habilitados e capacitados para cuidar e coordenar áreas tão sensíveis como a de segurança da informação, direito digital e proteção de dados (Dino, 2019).

O encarregado ou DPO será o especialista responsável por gerenciar os dados, pensar nas estratégias utilizadas pela organização, possuir conhecimentos em tecnologia e segurança da informação, além de habilidades políticas, já que será o elo da empresa com os órgãos reguladores.

Em uma pesquisa realizada com 40 clientes da Gartner no Brasil durante um webinar, 73% afirmaram ainda não ter escolhido um DPO e buscam determinar a quem esta posição deve reportar. Para os 11 clientes que já possuem a função, 5 reportam a um executivo da TI e os outros 6 reportam a uma função fora de TI.

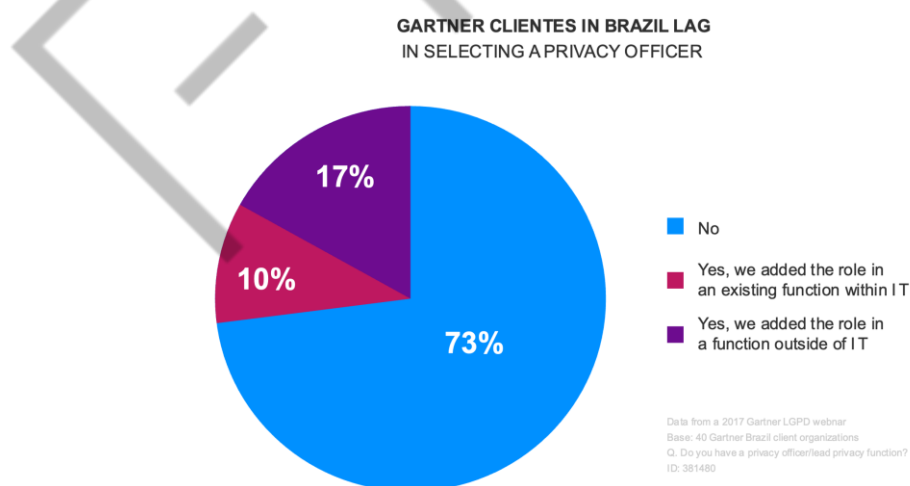


Figura 7 – Data from Gartner's 2017 LGPD webinar among clients in Brazil
Fonte: GARTNER (2019)

Sobre a definição de posicionamento do encarregado, a Gartner recomenda que questões de privacidade frequentemente requerem uma resposta explicitamente legal, então ter o DPO atrelado ao departamento jurídico – e às vezes até ser um advogado – é útil para lidar com tais questões. Estas características fizeram surgir, no mercado, a expressão “*technolawyer*” em referência a um “advogado-técnico” ou um “técnico-advogado”.

4 O PAPEL DA TI NA LGPD

É muito comum haver uma associação direta entre a Lei Geral de Proteção de Dados e a área de tecnologia da informação. Tal associação possivelmente é motivada pelo fato de a TI ser, cada vez mais, estratégica aos negócios e, conseqüentemente, todo processamento de informações, incluindo os dados pessoais acabam passando por esta área. Normalmente, quando pensamos em uma lista com dados de clientes ou as informações sobre os empregados de uma organização, associamos isso a algum tipo de banco de dados e sistemas de informações especialistas, mas isso não é, necessariamente, uma regra.

O Art. 1º menciona:

Esta Lei dispõe sobre o tratamento de dados pessoais, inclusive nos meios digitais, por pessoa natural [...], ou seja, apesar de desempenhar um importante papel na busca da conformidade com a LGPD, a área de Tecnologia da Informação e ou a área de segurança da informação não devem ser vistas como as únicas responsáveis.



Figura 8 – Top Secret
Fonte: Adaptado por FIAP (2019)

Neiva e Willemsen (2019) afirmam que toda organização deve ser cautelosa sobre tornar a TI ou a segurança responsável por tudo que se refere à proteção de dados. A privacidade não é uma preocupação apenas tecnológica. Em vez disso, a privacidade também se relaciona com requisitos legais e de conformidade.

Envolver todas as áreas é uma missão antiga dos CISOs e agora é mais importante do que nunca: trazer a responsabilidade para toda a organização, dos diretores ao estagiário, e mostrar que o cuidado com a proteção dos dados é um dever de todos os colaboradores (Machado, 2019).

Apesar de necessária interação e suporte de diversas áreas da organização, como recursos humanos, compras, jurídico, conformidade, auditoria, entre outras, as áreas de tecnologia da informação e segurança desempenham importantes papéis na adequação dos processos corporativos à LGPD.

Para se adequarem à Lei, as empresas precisaram fazer investimentos em novas soluções, como sistemas de avaliação de riscos de terceiros, gestão de dados, mascaramento de dados, portais seguros de transferência de dados, bancos de dados seguros e de alta volumetria, gestão de identidade de consumidores e clientes, além da adoção de práticas e arquiteturas tecnológicas que considerem a proteção de dados por padrão ("*security by design*"), por exemplo, a encriptação nativa de dados pessoais quando forem coletados, a guarda segura destes dados em ambientes controlados e seguros, e o acesso controlado dos dados por meios seguros (Kiyohara, 2018).

O conceito de *security by design* mencionado por Kiyohara (2018) pode ser complementado pelo conceito de *privacy by design*. Ambos são práticas que auxiliam o cumprimento da lei e que, até agora, eram incorporadas ao desenvolvimento e arquitetura de TI devido à necessidade de segurança, mas passam a ser necessidade legal.

Privacy by Design é uma metodologia na qual a proteção de dados pessoais é pensada desde a concepção de sistemas, e seu conceito foi resumido e simplificado em 7 princípios básicos (Faria, 2019):

- 1) Ser proativo e não reativo (prevenir e não remediar) – Prever e antecipar eventos que possam comprometer a privacidade antes que eles ocorram.

2) Privacidade como configuração padrão – Por padrão, as configurações referentes à privacidade devem estar definidas considerando a máxima proteção possível da privacidade do usuário.

3) Privacidade incorporada ao projeto – A proteção dos dados pessoais deve ser pensada como parte indissociável do projeto de arquitetura do sistema ou da prática de negócio, ou seja, desde a concepção.

4) Funcionalidade total – “Soma-positiva” em vez de soma-zero – Esse princípio visa garantir a proteção de dados pessoais em consonância com os legítimos interesses e objetivos daqueles que utilizam as informações, sem a necessidade de se fazer trocas desnecessárias, por exemplo, abrir mão da segurança para conseguir mais dados.

5) Segurança de ponta a ponta – A segurança das informações pessoais deve ser garantida desde a coleta do dado até sua destruição ou compartilhamento com um terceiro.

6) Visibilidade e transparência – Abrange diversos aspectos, como informar ao titular do dado quando e para qual finalidade as suas informações estão sendo coletadas até a abertura da plataforma para que entidades independentes possam realizar auditorias e certificar-se de que as informações pessoais estão de fato protegidas.

7) Respeito pela privacidade do usuário (solução centrada no usuário) – Toda a arquitetura e a operacionalidade do sistema ou da prática de negócio devem ser centradas na privacidade do usuário, oferecendo medidas robustas de proteção de dados, notificando-o de forma clara e oportuna e tornando as configurações referentes à privacidade amigáveis.

Ainda sobre o papel que a TI deve desempenhar, Machado (2019) pontua a importância de se investir em ferramentas tecnológicas: Agora sim é hora de a tecnologia mostrar para que veio e auxiliar em todo processo de classificação da informação, visibilidade, controles, resposta a incidentes e prevenção.

Sobre as afirmações de Machado (2019), podemos destacar algumas soluções tecnológicas que podem auxiliar neste processo:

- **Soluções de Criptografia:** Possibilita a proteção de bancos de dados estruturados ou não, *on premises* ou em nuvem. Mesmo que ocorra um vazamento destes dados, estes não poderão ser utilizados e não causarão danos aos proprietários.
- **WAF (Web Application Firewall):** Sistema de segurança intermediário entre os sites/aplicativos e a WEB. Protege (basicamente) sites, *e-commerce*, blogs, aplicativos móveis, entre outros de ataques externos.
- **Gestão de identidade:** Controla a identidade digital que deve ser segura, única e intransferível, dos ativos relacionados à informação, como pessoas, equipamentos, aplicações etc.
- **DLP/CASB (Data Loss Prevention/Cloud Access Security Broker):** Ferramentas ou serviços que garantem a correta utilização, distribuição, transferência ou extração de dados armazenados internamente ou em nuvem.
- **IPS (Intrusion Prevention System):** Solução tecnológica que, como o nome sugere, atua na prevenção às ameaças do ambiente de rede. Garante proteção na camada de comunicação dos clientes.
- **SIEM (Security Information and Event Management):** Gerencia e correlaciona eventos de segurança. Com a centralização e o correlacionamento dos eventos gerados por outras aplicações de segurança (*antimalware, firewalls, proxies, IPS, entre outros*), possibilita identificação e resposta aos incidentes.

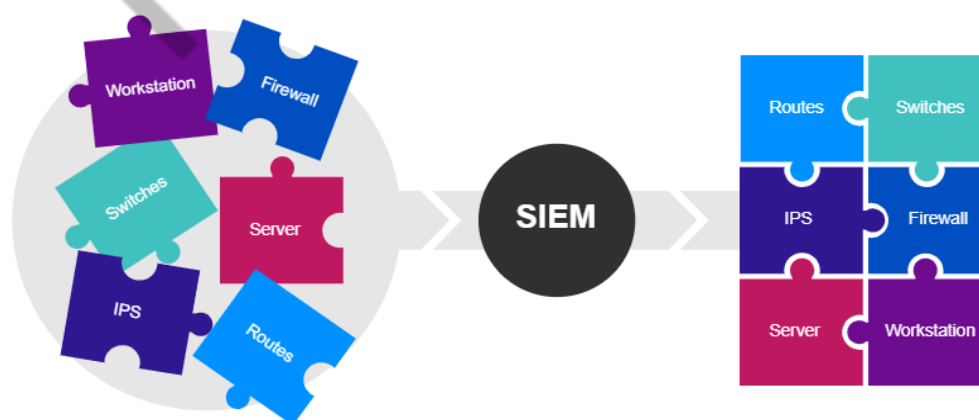


Figura 9 – SIEM

Fonte: TRITIUM INFORMATION SECURITY (20217). Adaptado por FIAP (2019)

Ainda sobre o uso das ferramentas e soluções tecnológicas, Cordeiro (2019) pondera que criptografar informações, controlar acessos, habilitar autenticação, criar camadas de segurança, fazer análises e testes de segurança etc., todo este universo de GRC – governança, riscos e *compliance* – tem plena aderência à lei. Por isso, pode-se dizer que o impacto da LGPD nas empresas deverá ser bastante diferente, dependendo do histórico e políticas prévias de segurança.

Como deve ter ficado claro até aqui, as demandas são complexas, mas com o comprometimento de todos os times envolvidos e com a tecnologia auxiliando e dando vazão às automações necessárias, a aderência à Lei virá naturalmente.

PONTES, Sergio. **O que fala a Lei Geral de Proteção de Dados Pessoais - Lei 13.709/2018.** 2018. Disponível em: <<https://sergiopontes.iusbrasil.com.br/artigos/614642198/o-que-fala-a-lei-geral-de-protecao-de-dados-pessoais#:~:text=A%20Lei%20n%C2%BA%2013.709%2F2018,mesmo%20por%20o%20utras%20pessoas%20f%C3%ADsicas>>. Acesso em: 30 ago. 2024.

PORTO JUNIOR, Odélio. **Tipos de Consentimento e Proteção de Dados Pessoais: Um Breve Histórico.** 2018. Disponível em: <[https://irisbh.com.br/tipos-de-consentimento-e-protecao-de-dados-pessoais/#:~:text=Desde%20a%20introdu%C3%A7%C3%A3o%20da%20Diretiva,\(3\)%20o%20consentimento%20ativo](https://irisbh.com.br/tipos-de-consentimento-e-protecao-de-dados-pessoais/#:~:text=Desde%20a%20introdu%C3%A7%C3%A3o%20da%20Diretiva,(3)%20o%20consentimento%20ativo)>. Acesso em: 30 ago. 2024.

SANTIAGO, Fernando. **Lei de proteção de dados muda funcionamento de empresas brasileiras.** 2018. Disponível em: <<https://www.migalhas.com.br/dePeso/16,MI285939,11049-Lei+de+protecao+de+dados+muda+funcionamento+de+empresas+brasileiras/>>. Acesso em: 30 ago. 2024.

TRITIUM INFORMATION SECURITY. **10 Reasons To Break Up With Your Legacy SIEM.** 2017. Disponível em: <<https://www.tritium-security.com/single-post/2018/05/02/10-Reasons-To-Break-Up-With-Your-Legacy-SIEM>> . Acesso em: 30 ago. 2024.

GLOSSÁRIO

DPO	<i>Data Protection Officer.</i>
LGPD	Lei Geral de Proteção de Dados.
GDPR	<i>General Data Protection Regulation.</i>
ANPD	Autoridade Nacional de Proteção de Dados.
DADO PESSOAL	Informação relacionada a pessoa natural identificada ou identificável.
DADO PESSOAL SENSÍVEL	Dado pessoal sobre origem racial ou étnica, convicção religiosa, opinião política, filiação a sindicato ou a organização de caráter religioso, filosófico ou político, dado referente à saúde ou à vida sexual, dado genético ou biométrico, quando vinculado a uma pessoa natural.
CISO	<i>Chief Information Security Officer.</i>
ON PREMISES	Uso de servidor ou recursos de TI dentro da empresa.